

The effects of APT and Ransomware on Australian critical infrastructure

Author: Hafsa Nooruddin

Executive Summary

This report delves into the cybersecurity threat landscape surrounding critical infrastructure companies, specifically emphasising recent trends impacting large corporations in the following industries: Telecommunications, Government, Healthcare, Finance and Energy. The analysis sheds light on evolving attackers and their methodologies, emphasising their strategic focus on critical infrastructure entities in Australia and worldwide.

The report navigates through potential threats outlined in various scenarios, employing MITRE ATT&CK techniques and associated threat models. From credential compromise to the spectre of ransomware and DDoS attacks, the report studies attack vectors, vulnerabilities and techniques that require an enhanced cybersecurity posture.

To counteract these threats, the report provides a comprehensive list of mitigations ranging from foundational methods to advanced technology. Organisations can strengthen their defences by adopting these mitigations, ensuring a resilient security posture against the emerging cyber risks outlined in this report.

In summary, the report serves as a resource for critical infrastructure companies, informing them of evolving cyber threats consolidated through open-source intelligence reports. It also urges organisations to follow cyber threat intelligence and stay alert and informed on trends within the cyber threat landscape through proactive threat actor tracking, which can enhance their situational awareness.

This will not only strengthen their cybersecurity defences but also contribute to the safeguarding of Australia's critical infrastructure against persistent and sophisticated adversaries.

Introduction

The cyber threat landscape represents the dynamic and ever-evolving space where hackers, cybercriminals, nation-states, and other threat actors engage in tactics, techniques, and procedures aimed at exploiting vulnerabilities, conducting illicit financial activities, compromising data, and disrupting the digital fabric of our interconnected world.

The threat landscape and organisation's attack surfaces are constantly transforming, as the ability of threat actors to develop new techniques and gain access to new technology poses a significant risk for businesses and industries of all sizes. In recent years, Australia's cyber threat landscape has evolved dramatically; cybercriminals and nation-states are increasingly targeting Australian critical infrastructure companies for purposes such as monetary gain and data theft. Advanced persistent threats have continued to exploit vulnerabilities, and ransomware attacks have surged, posing significant risks to the nation's most prominent organisations. Critical infrastructure industries such as Healthcare, Telecommunications, Government Agencies, Finance and Energy have been consistently targeted by malicious actors worldwide; in Australia, these industries are dominated by the following firms, respectively: Centrelink, Sonic Healthcare, Telstra, Commonwealth Bank of Australia and AGL Energy. These companies not only drive economic growth but also play a pivotal role in safeguarding our nation's well-being. Thus, any compromise of their data or disruption to their services could have many lasting implications for Australian society. This report aims to profile the emerging advanced persistent threats and ransomware campaigns that potentially threaten Australia's largest companies and explore the impacts these threats may bring to these vital entities. In the face of these evolving challenges, it is imperative that we gain a deeper understanding of the ever-shifting threat landscape and equip these organisations with insights and strategies to safeguard their operations and our nation's critical infrastructure.

Methodology

In conducting comprehensive research and analysis of cyber threats affecting Australia's largest companies, it is imperative to acknowledge and address inherent limitations that have impacted the outcome of this report. A notable limitation occurred due to needing access to internal reports detailing the organisations' cybersecurity postures. Internal reports typically offer nuanced insights into sensitive information such as an organisation's assets, recent security incident details/logs, specific security measures employed and vulnerabilities within a system. Their absence within this study issued a strategic reliance on open-source intelligence reports from reputable sources, i.e. Mandiant, CrowdStrike and Australia Cyber Security Centre (ACSC). All of which compiled threat intel regarding trends within the cyber threat landscape, such as common attack vectors, tactics, techniques and procedures, active cyber threat actors and their respective motives. This approach allowed for a focus on external perspectives and ensured the study leveraged high-quality, industry-validated data to compensate for the absence of internal data. However, with this, it is essential to note that the rapid developments of events within the cyber world mean some data in this study may need to reflect the latest developments. Similar to their sources, specific findings within this report represent only a snapshot in time, and ongoing vigilance is essential in understanding the continually changing threats to critical infrastructure entities.

Another challenge emerging through the research process involved the assessment of priorities and relevant information within the expansive scope of this study. As the research question had quite a broad scope, it required careful consideration and focus to ensure findings pertinent to the current timeline and cyber threat landscape. As a result, the focal point of this report has been the threats against critical infrastructure companies – which was found to be a high priority reflecting the current

trends in the cyber threat landscape as attackers have targeted critical infrastructure in the years 2022-2023 at consistent and phenomenal rates. Finally, by addressing the above limitations during this project's planning and research phase, the methodology ensures transparency, contextually aware insights, and a concentrated effort to uncover the cyber threat trends within critical infrastructure.

Australian Critical Infrastructure

Critical infrastructure entails the essential services and systems that support the functioning of a nation. As cyber threat actors are increasingly targeting these entities, businesses must safeguard their assets and understand adversary targets and motives. According to Mandiant's recent M-Trends report and the Australian Cyber Security Centre's Annual cyber threat report, the following industries have been consistently targeted in 2021 and 2022.

Government Agencies - 34%

Healthcare – 9%

Information media and Telecommunications – 8%

Financial Institutions – 4%

Water, Electricity and Energy Providers – 3%

Australian critical infrastructure networks regularly faced attacks by malicious cyber activity; the leading cyber security incident types affecting them were due to compromised credentials, accounts, assets, networks, infrastructure, and denial of service attacks. These incident types accounted for approx—57% of all incidents affecting critical infrastructure between 2022 and 23. Data breaches and malware infections have also been quite prominent incident types during this period, according to the ACSC.

Australia's largest companies

Centrelink

Centrelink, operated by the Australian Government Department of Human Services (DHS), holds a unique position as a vital agency responsible for delivering essential social services and financial support to eligible individuals and families across Australia. Its comprehensive services encompass income support payments, family assistance, aged care support, and disability services. Centrelink's critical role in distributing financial assistance and managing sensitive personal information makes it an enticing target for cyber attackers, including state-sponsored actors and cybercriminals. Government agencies like Centrelink often store a wealth of sensitive data, including personal identifiers, financial records, and health information, which makes them highly sought after by cyber adversaries. State-sponsored actors may target Centrelink to gain access to valuable citizen data for espionage, identity theft, and other malicious purposes. Cybercriminals also recognise the financial value of such data, aiming to

exploit it for fraud, identity theft, and other illicit activities. The significance of Centrelink's cybersecurity measures cannot be overstated, as any breach or compromise could have far-reaching consequences, including financial loss for individuals and potential threats to national security. Ensuring the confidentiality, availability, and integrity of client data and social support systems is not only a matter of safeguarding individuals but also a crucial element of maintaining public trust in government institutions. As such, it is recommended that Centrelink remains vigilant and proactive in its efforts to thwart cyber threats and protect the well-being of Australians who rely on its services.

Sonic Healthcare

Sonic Healthcare, a global leader in medical diagnostics, operates in an industry where cyber attackers exceptionally seek healthcare data. The allure of healthcare data lies in its depth and richness. Patient records encompass a treasure trove of sensitive information, including medical histories, personal identifiers, insurance details, and, in some cases, financial data. This makes healthcare organisations like Sonic Healthcare prime targets for cybercriminals. Threat actors can exploit healthcare data for various malicious purposes, such as identity theft, insurance fraud, prescription drug abuse, and even ransom demands. Moreover, as healthcare institutions rely increasingly on digital systems for patient management, diagnostic analysis, and record-keeping, the volume of valuable data becomes more significant. Consequently, Sonic Healthcare's vigilant commitment to cybersecurity is not only essential for safeguarding patient privacy but also for maintaining the trust and reliability of its diagnostic services in an environment where healthcare data is an exceptionally prized commodity for cyber attackers.

Telstra

Telstra, Australia's largest telecommunications and technology company, stands as a linchpin in the nation's communication landscape. Renowned for its comprehensive suite of services encompassing mobile and fixed-line voice and data, broadband internet, cloud computing, cybersecurity solutions, and digital content, Telstra serves an expansive customer base. With millions of customers spanning individuals, SMEs, large corporations, government entities, and critical infrastructure organisations, Telstra's reach extends across Australia. This extensive customer base places Telstra at the forefront of safeguarding connectivity for personal and business communication needs, making it a vital player in Australia's critical communication infrastructure.

Commonwealth Bank of Australia

The Commonwealth Bank of Australia, commonly known as CommBank, stands as a cornerstone of Australia's financial sector. Established in 1911, CommBank boasts a rich history and a prominent role in the nation's economic landscape. With an extensive array of financial services, including personal and business banking, investment, insurance, and cutting-edge digital banking solutions, CommBank caters to a diverse clientele. Its customer base spans individual consumers, small businesses, multinational corporations, government entities, and financial institutions, embodying its vital role in the Australian banking and financial services industry. CommBank's far-reaching influence in facilitating economic transactions and financial stability underscores its significance as a critical institution within the nation's financial infrastructure, necessitating a robust approach to cybersecurity to protect the financial well-being of millions of Australians.

AGL Energy

AGL Energy, a prominent integrated energy company based in Sydney, Australia, boasts a rich history dating back to 1837. With its comprehensive offerings spanning electricity generation, natural gas production and distribution, renewable energy solutions, and energy retail services, AGL plays a pivotal role in Australia's energy landscape. Its extensive customer base encompasses residential consumers, businesses, industrial sectors, and government agencies, making AGL instrumental in powering homes, enterprises, and industries. The company's critical infrastructure, including power plants and energy distribution networks, underpins the reliable supply of electricity and gas to millions of Australians, contributing significantly to the nation's energy security and economic vitality. Given its indispensable role, it is vital that AGL prioritises robust cybersecurity measures to protect energy generation and distribution infrastructure from cyber threats, ensuring the reliability of energy supply and safeguarding the interests of customers and the broader community.

Cyber Threat Profiles

Threat profiling is a vital aspect of cybersecurity, particularly in the context of advanced persistent threats (APTs), cyber-criminal gangs and ransomware. Threat profiling allows organisations to create detailed profiles of these adversaries, understanding their tactics, techniques, and motivations, thereby helping in the development of targeted and adaptive security measures.

Types of threats:

Nation-State Actors/APTs

Nation-state actors, who are often referred to as APTs, are groups of skilled threat actors that are sponsored by a specific nation-state government, employed to target other countries' infrastructure, often engaging in long-term, covert cyber operations such as espionage, data theft, sabotage, influence operations and other cyber warfare activities that involve the disruption of critical infrastructure. The main thing that sets nation-state actors apart is that they operate on a global stage, and they are highly skilled and well-resourced cyber adversaries whose motives are typically driven by a combination of geopolitical, economic, and strategic interests.

The top sponsors of state-hacked cybercrime include the following:

- Russia
- Iran
- North Korea
- China

Examining the impact of the Russia and Ukraine War on Australia's threat landscape:

Political tension between nations is often a catalyst for nation-state and APT-led cyber warfare, and within the current geopolitical climate, the war between Russia and Ukraine is a prime example of this notion. The impacts of consistent attacks targeting a nation's critical infrastructure were displayed to the world with Russia's targeting of the Ukrainian crucial infrastructure in their attacks over the years. Currently, both parties are engaged in cyber warfare, utilising state-sponsored cyber campaigns against one another's critical infrastructure. As a result, Russia has mobilised their notorious APT groups and has deployed a series of sophisticated DDOS attacks on Ukrainian critical infrastructure, such as energy grids, telecommunications systems, and government networks. Evolving intelligence also suggests Russia is poised to target critical infrastructure in other countries, expanding the scope of its cyber operations beyond the Russia-Ukraine conflict. Yet, it remains improbable that Russian intelligence or military cyber actors will directly target Australia. There is more of a chance of Australian organisations suffering collateral damage because of a recklessly used cyber weapon on vendors and supplies. However, in the first year of the conflict, there was a reported increase in attacks by pro-Russian hacktivists in European countries (Germany, Spain, the UK) and the US. This rise in hacktivism poses a threat to Australia, whose government has imposed sanctions on Russia and unequivocally supports Ukraine in this war. The evolving situation demands heightened cybersecurity measures globally, as the ripple effects of this cyber warfare extend beyond regional boundaries.

Examining China-nexus Espionage Actors:

Volt Typhoon

Since the mid-2021 period, Volt Typhoon, a Chinese state-sponsored actor specialising in cyber disruption and information gathering, has been actively targeting critical infrastructure organisations. Microsoft, with moderate confidence, has assessed that Volt Typhoon is actively working to develop capabilities aimed at disrupting communication infrastructure in the Pacific region. Government advisories have also warned that the Volt Typhoon poses a potential threat to various critical infrastructure sectors across different countries, including Australia.

The group's targets span a wide range of sectors, including communications, manufacturing, utilities, transportation, construction, maritime, government, information technology, and education. The observed behaviour suggests that the threat actor's primary goal is intelligence gathering, with an emphasis on maintaining undetected access for an extended period.

Engaging a broad spectrum of sectors, including communications, manufacturing, utilities, transportation, construction, maritime, government, information technology, and education, the group demonstrates a primary focus on intelligence gathering. Emphasising the importance of maintaining undetected access for an extended period, their observed behaviour reflects a strategic approach.

A key tactic employed by the threat actor involves "living off the land," utilising inherent network administration tools to achieve their objectives. This approach enables them to blend within regular Windows system and network activities, avoiding detection by endpoint detection and response (EDR) products that typically alert on the introduction of third-party applications. Additionally, this

tactic helps limit the amount of activity captured in default logging configurations. Notable built-in tools utilised by this actor include wmic, ntdsutil, netsh, and PowerShell.

The initiation of their access occurs through internet-facing Fortinet FortiGuard devices, where they extract credentials to facilitate lateral movement within the target networks. To enhance the stealth of their operations, the attackers also leverage compromised small office and home office (SOHO) network devices to route their network traffic. This multifaceted approach contributes to the sophistication and effectiveness of their activities, which has allowed Volt Typhoon attackers to demonstrate a high level of skill and sophistication in their past operations. As a result, it is imperative for Australian critical infrastructure companies to stay informed on the groups' activities and exercise vigilance and caution considering these skilled threat actors.

Cyber-criminal groups:

Financially motivated cybercriminals form a significant and diverse category within the realm of cyber threats. Driven primarily by profit, these individuals or groups engage in a wide range of illicit activities with the aim of financial gain. Their tactics include conducting ransomware attacks to extort money from individuals and organisations, carrying out identity theft and financial fraud schemes, stealing and selling valuable data on underground markets, and orchestrating phishing campaigns to compromise banking and payment credentials. In more recent years, cybercriminals have focused on a new method of financial extraction: cryptocurrency, which provides more anonymity as cryptocurrency transactions are challenging to trace, coupled with the lack of regulation in the field, creating numerous opportunities for extortion. Financially motivated cybercriminals often operate with a high degree of sophistication and adaptability, leveraging the latest hacking techniques and tools. Their activities pose a substantial threat to individuals' financial security and the economic stability of businesses and industries, necessitating constant vigilance and robust cybersecurity measures to counter their actions.

Scattered Spider - UNC3944

UNC3944, also known as Scattered Spider, emerged as a financially motivated threat cluster in May 2022. Initially focusing on telecommunications and Business Process Outsourcing organisations from December 2022, the group has expanded its target scope to include critical infrastructure sectors.

Despite diversifying their targets, Scattered Spider remains committed to employing a range of social engineering tactics in their attacks. Utilising Telegram and SMS phishing, SIM swapping, MFA fatigue, and other methods, the group displays a nuanced understanding of cloud environments, particularly Azure. Their track record includes compromising various platforms such as Windows, Linux, Google Workspace, Azure Active Directory, Microsoft 365, and AWS.

The group's modus operandi involves intricate steps such as reconnaissance, lateral movement, and the exfiltration of sensitive data, with a notable focus on VPN and MFA enrolment data. Scattered Spider often establishes persistence using legitimate remote access tools like Any Desk and LogMeIn. Their deceptive tactics involve impersonating IT personnel to manipulate individuals into sharing credentials or granting remote access.

In their campaign against Telecom companies, Scattered Spider targeted mobile carrier networks to perform SIM swapping activities, as evidenced in two investigations. The group also engaged in attestation signing to sign malware and collaborated with the ransomware group ALPHV to deploy ransomware on MGM Resorts' systems. The impact of their actions extends to unauthorised access to information, including mobile phone numbers and SMS messages, affecting organisations in the technology, telecommunications, and cryptocurrency sectors.

Given their persistent and bold actions, Scattered Spider poses a significant cybersecurity concern. This is particularly true for companies like Telstra, where the potential for network compromise and disruption within the telecommunications sector is a looming threat.

FIN11/Clop Ransomware

FIN11, a notorious cybercriminal group, gained infamy for deploying the Clop ransomware variant. This group has consistently orchestrated high-profile ransomware attacks against a broad spectrum of organisations and individuals spanning diverse sectors. Notably, during the COVID-19 pandemic, FIN11 directed its focus towards pharmaceutical companies and healthcare targets, continuing to prioritise the health sector.

Operating since 2019, FIN11 has fallen under the scrutiny of Mandiant; it has been identified as a threat cluster. In the wake of the pandemic, their Clop ransomware attacks expanded to encompass a broader array of entities, including educational facilities, government agencies, and corporations. Cybersecurity researchers report that Clop has successfully targeted at least 230 firms, with a significant data extortion campaign impacting MoveIT file transfer service customers. This campaign exploited a zero-day vulnerability, specifically a critical SQL injection bug in the secure file transfer service. Notable victims, including major Australian firms like PwC and Shell, have disclosed breaches in the aftermath.

Clop's success lies in its "double extortion" tactic, where the group not only encrypts victims' data but also exfiltrates sensitive information. Subsequently, cybercriminals leverage the threat of publishing or selling this data on the dark web unless the ransom is paid. Typically, the group demands substantial ransoms in cryptocurrencies in exchange for decryption keys.

The broader recommendation to organisations and individuals is to fortify their cybersecurity defences and remain vigilant against ransomware threats like Clop. The evolving tactics and extensive

reach of FIN11 underscore the critical need for proactive measures to mitigate the impact of such cyber threats.

Ransomware-As-A-Service

Ransomware-As-A-Service is a business model in which ransomware is developed by cyber criminals or ransomware groups for lease to affiliates. This allows cybercriminal affiliates to launch sophisticated and highly effective attacks without the need for extensive technical expertise or coding skills. This democratises access to ransomware tools and increases the frequency and scale of ransomware attacks, posing significant risks to individuals, businesses, and critical infrastructure globally. The decentralised nature of RaaS further complicates law enforcement efforts, making it challenging to track and apprehend those responsible for orchestrating these attacks.

ALPHV

ALPHV, also known as BlackCat or Noberus, emerged on the radar in late 2021 as a ransomware-as-a-service (RaaS) affiliate program associated with Russian-speaking cybercrime actors. Open-source reporting indicates a connection between ALPHV and previous ransomware variants, as their operators actively seek former members of BlackMatter, DarkSide, and REvil groups for recruitment, evident in the similarities in the TTPs employed by ALPHV and BlackMatter ransomware actors.

ALPHV's advertising of the ransomware occurs in private forums like the darknet platform RAMP, and their affiliates have effectively deployed ransomware on global networks, including instances in Australia. The group's targets extend to government and critical infrastructure organisations, as well

as sectors such as energy, finance, and construction. A distinctive feature of ALPHV ransomware is its capability to target both Windows and Linux systems.

Various initial access vectors are employed by threat actors associated with ALPHV, including exploiting known vulnerabilities, obtaining legitimate credentials through phishing attacks or brute force, and deploying reverse SSH tunnels for command-and-control purposes. ALPHV ransomware exhibits disruptive capabilities, terminating VMware ESXi virtual machines and deleting backups to hinder recovery efforts.

The group's techniques involve PowerShell for modifying Windows Defender settings, PsExec for lateral movement, and the use of the Cobalt Strike tool for network access. Data exfiltration to public cloud file-sharing services is also part of their skill set. Following the encryption of victim data, ALPHV affiliates employ multiple extortion tactics, including uploading stolen data to a dedicated leak site on the TOR network, issuing threats to release additional information, and even resorting to Distributed Denial of Service (DDoS) attacks if ransom demands are not met. This multifaceted approach underscores the sophistication and adaptability of ALPHV in their ransomware operations.

LockBit 3.0

LockBit 3.0 stands out as a formidable ransomware strain notorious for encrypting victims' files and employing a ransom-for-decryption scheme. Evolving over time, the new variant employs advanced encryption techniques and a double extortion tactic, not only locking files but also stealing sensitive data and threatening its release if the ransom remains unpaid.

In the year 2022, LockBit emerged as the most widely deployed ransomware variant globally, constituting 18% of ransomware attacks, with Australia being no exception. Its prolific nature persists into 2023. Since January 2020, LockBit affiliates have targeted organisations of varying sizes across critical infrastructure sectors, including financial services, food and agriculture, education, energy, government and emergency services, healthcare, manufacturing, and transportation.

Operating on a Ransomware-as-a-Service (RaaS) model, the LockBit ransomware operation recruits affiliates to execute ransomware attacks using LockBit tools and infrastructure. The large number of unconnected affiliates within the operation leads to significant variations in observed TTPs during LockBit ransomware attacks. This variability poses a notable challenge for organisations striving to maintain network security and defend against ransomware threats.

Commonly, LockBit 3.0 propagates through phishing emails and exploit kits. During intrusions, LockBit affiliates utilise various freeware and open-source tools initially intended for legal purposes. Repurposed by LockBit, these tools serve malicious cyber activities, including network reconnaissance, remote access and tunnelling, credential dumping, and file exfiltration. Like many other threat actors today, PowerShell and batch scripts feature prominently across affiliates' intrusions for purposes such as system discovery, reconnaissance, password/credential hunting, and privilege escalation. This multifaceted approach highlights the adaptability and sophistication of the LockBit 3.0 ransomware operation and its ongoing threat to all types of organisations throughout the world.

Commonalities in Attack vectors and TTP

Common Initial Infection Vectors in 2022-2023

Exploits – 32%

Phishing – 22%

Stolen Credentials – 14%

Prior compromise – 12%

These four primary attack vectors have been identified by Mandiant as the most prominent initial infection vectors used by attackers between the years 2022-2023. Exploits have continued to be the most leveraged attack vector as threat actors have focussed on leveraging vulnerabilities in software and systems. Phishing, as the second most popular attack vector, involves social engineering tactics to deceive individuals into disclosing sensitive information – in doing so, Phishing remains one of the most successful attack methods. Adversaries also leverage stolen credentials obtained through Phishing, data leaks, or other means to gain access to a system – remaining as a pervasive attack vector. Additionally, leveraging prior compromises has been a common infection vector, especially within Australia, as attackers have utilised existing footholds and vulnerabilities to carry out more sophisticated and persistent attacks. By building upon initial compromises, attackers can navigate laterally, escalate

privileges, and maintain long-term presence and access within business systems, highlighting the critical need for the robust cybersecurity measures and mitigation discussed later in this study. Furthermore, considering the outlined cybersecurity challenges of these attack vectors, the table below (Table A) provides a more detailed breakdown of the most common techniques used in infiltrations by threat actors.

Table A

MITRE ATT&CK Phase	Technique	Technique ID	Attack Vector
Reconnaissance	Phishing	T1566.001	Social Engineering
Reconnaissance	Voice Phishing	T1566.002	Social Engineering
Reconnaissance	Spear Phishing Attachment	T1566.003	Social Engineering
Reconnaissance	Spear phishing via Service	T1566.004	Social Engineering
Reconnaissance	System Information Discovery	T1082	Active Reconnaissance
Initial Access	Access Token Manipulation	T1552.001	Credential Access

Initial Access	MFA Exploitation	T1552.003	Credential Access
Initial Access	Stolen Credentials	T1552.004	Credential Access
Initial Access	Remote Desktop Services/VMware	T1021.001	Lateral Movement
Execution	Command and Scripting Interpreter	T1059.001	Execution
Execution	Obfuscated Files or Information	T1027	Execution
Execution	PowerShell	T1059.001	Execution
Persistence	Create or Modify System Process	T1543.003	Persistence
Command and Control	Backdoor Malware	-	Command and Control
Privilege Escalation	Access Token Manipulation	T1552.001	Privilege Escalation
Defence Evasion	Living off the Land	T1140	Defence Evasion
Discovery	System Information Discovery	T1082	Active Reconnaissance

Discovery	File and Directory Discovery	T1005.003	Discovery
Collection	File and Directory Discovery	T1005.003	Discovery
Exfiltration	Tunnelling	T1041.001	Exfiltration
Execution	File Deletion	T1070.004	Execution
Collection	Service Execution	T1569.002	Discovery
Command and Control	Remote Desktop Protocol	T1021.001	Command and Control

Threat Modelling

In the realm of cybersecurity, understanding an organisation's assets and the threats it faces is paramount. This section delves into this crucial analysis, identifying critical assets and profiling the diverse array of threats that may have an impact on Australia's largest companies. Threats profiled within this section may be organisation-specific or apply to the whole of Australian critical infrastructure. Thus, it is imperative that an adversary's targets and an organisation's assets are considered to determine the true scope of threats. Additionally, the leading cyber security incident types affecting Australia's critical infrastructure between the years of 2022 and 2023 were compromised accounts/credentials, assets, networks, infrastructure, and denial of service attacks. Understanding these threats is critical for effective risk management and cybersecurity preparedness. As a result, the

scenarios below will focus on these incident types and the common attack vectors and techniques discussed earlier.

Centrelink

Identifying key assets

- Client Data and Information systems are critical for managing client records, processing benefit claims, and ensuring the confidentiality and security of sensitive information. Centrelink holds a mass amount of data on its customers, including personally identifiable information, financial data, family and household details, employment history, medical and health information, customer history, citizen and residency status, education, criminal history, banking and payment information, etc.
- Payment Systems
- Information technology infrastructure such as servers, databases, and network infrastructure are essential for the operation of Centrelink's online and internal systems.
- Contact Centres and customer support services
- Physical facilities such as offices.

Methods of attack:

Advanced Persistent Threat Campaign

Threat Model #1

As discussed earlier in the organisation profile, Centrelink stores numerous records of financial data pertaining to its clients, who consist of both individuals and businesses. Additionally, these records contain personal identifiers, medical information, and other sensitive data that are highly sought after by both state-sponsored actors and cybercriminals. The threat model below explores the tactics, techniques, and procedures a state-sponsored actor like Volt Typhoon would apply to launch a cyber campaign on Centrelink for the purposes of espionage and exploitation.

Stage 1: Reconnaissance and Targeting

Volt Typhoon conducts extensive reconnaissance on Centrelink's systems and operations, identifying vulnerabilities. They seek out information on Centrelink clients and their financial details.

Stage 2: Initial Compromise

Volt Typhoon uses spear-phishing campaigns, exploiting known vulnerabilities or leveraging social engineering to gain initial access to Centrelink's network.

They may exploit zero-day vulnerabilities in software or firmware of targeted devices.

Stage 3: Lateral Movement

After initial access, Volt Typhoon employs their living off the land technique, using built-in network administration tools like PowerShell, wmic, and ntdsutil to move laterally within Centrelink's network.

The group attempts to escalate privileges, seeking databases and servers containing sensitive client data.

Stage 4: Data Exfiltration

Volt Typhoon successfully locates, extracts, and encrypts sensitive data, including PII, financial records, and social security details from Centrelink's systems.

They employ valid accounts and proxy techniques to exfiltrate data while evading detection.

Stage 5: Impact

Centrelink clients become victims of identity theft, fraud, and potential financial losses.

Centrelink faces severe public backlash, media scrutiny, and legal consequences for the data breach.

Potential Consequences:

- **Identity Theft and Fraud:** Centrelink clients suffer from identity theft, fraudulent activities, and financial losses.
- **Reputation Damage:** Centrelink's reputation is significantly harmed, leading to a loss of public trust and confidence.
- **Legal and Regulatory Consequences:** Centrelink may face regulatory fines and legal actions for data breaches and failing to protect sensitive information.
- **Disruption to Government Operations:** The attack disrupts Centrelink's operations, leading to delays in providing essential social welfare services.

Telstra

Identifying key assets

Given the nature of Telstra's involvement across all business sectors and being the top telecommunications provider in the country, Telstra's critical assets look a lot like the following:

- **Communication Services** - including landline telephony, broadband internet, and wireless communication (mobile networks).
- **Network Infrastructure** - Telstra's extensive network infrastructure comprises a vast network of fibre-optic cables, sub-sea cables, and mobile towers, forming the backbone of Australia's telecommunications infrastructure.

- **Data Centres:** Data centres that support mobile network operations, hosting critical network elements and services.
- **Customer Data -** Customer information such as personal details, payment details, contact information, demographics, and customer preferences are valuable data assets.
- **Billing Systems -** These systems generate invoices, process payments, and maintain records of customer billing histories. Billing systems are assets because they ensure a steady stream of revenue and help track financial transactions.
- **Customer Support Systems -** Customer support systems, including customer relationship management (CRM) software and help desk platforms, are assets that enable companies to provide efficient and effective customer service.
- **Hardware and Software**

Methods of Attack:

Sim Swapping

For a telecommunications provider like Telstra, one of the main threats to the business and customers is SIM Swapping. SIM swapping attacks involve attackers fraudulently taking control of a victim's phone number by convincing the victim's mobile carrier to transfer the number to a new SIM card under the attacker's control. Cybercriminals with a focus on targeting telecom providers such as Scattered Spider have used this attack in the past to exploit SMS-based multi-factor authentication and compromise the victim's data and accounts, usually for the purposes of financial gain or identity theft. Scattered Spider is known for the theft of sensitive data and leveraging trusted organisational infrastructure for follow-on attacks on downstream customers.

Network Compromise

An adversary is likely to target Telstra to gain unauthorised access to the Telstra network and leverage this access to target and compromise other businesses that rely on Telstra's internal network infrastructure. The adversary aims to steal sensitive data whilst at work and perform data exfiltration. The threat model below explores how a cybercriminal group like Scattered Spider would employ their range of skills and expertise to launch a cyberattack on the Telstra network for the purposes of data exfiltration and financial gain.

Threat Model #2

Stage 1: Reconnaissance and Target Selection

The Scattered Spider Adversary begins by conducting extensive reconnaissance on Telstra's infrastructure and key personnel. They identify potential targets within the organisation who have access to sensitive information, such as customer databases and critical systems.

Stage 2: Phishing and Social Engineering

To gather insider information and compromise Telstra's employees, the adversary initiates a targeted phishing campaign. They craft convincing phishing emails and messages, impersonating trusted entities or colleagues to lure Telstra employees into disclosing their login credentials.

Stage 3: Sim Card Acquisition

With stolen credentials, the adversaries take the next step in their attack plan. They visit Telstra's physical stores or contact Telstra customer support to claim that the victim's SIM card is lost or stolen. They use the stolen credentials and personal information to pose as the victim convincingly.

Stage 4: Sim Swapping

The Scattered Spider Adversary convinces Telstra's customer support to issue a new SIM card for the targeted customer's phone number. This effectively transfers control of the victim's phone number to the adversary, as the new SIM card is inserted into a device controlled by the attackers. The victim's phone loses signal, and the attackers gain access to any two-factor authentication codes sent via SMS.

Stage 5: Unauthorised Access

With control over the victim's phone number, the adversaries can now access various online accounts linked to the victim's mobile number. They exploit this to infiltrate Telstra's internal systems, gaining access to customer data and billing information and even potentially compromising sensitive infrastructure.

Stage 6: Data Exfiltration and Ransom

The Scattered Spider Adversary, now armed with inside information and control over Telstra's systems, proceeds to exfiltrate sensitive customer data. They may then threaten to release this data unless a significant ransom is paid, potentially causing substantial damage to Telstra's reputation and finances.

Potential Consequences

- **Depleted Customer Trust:** The exposure of personal information could severely undermine the trust of Telstra's customer base, resulting in a loss of subscribers and revenue.
- **Financial Impact:** Telstra may face substantial financial repercussions stemming from customer compensation, regulatory fines, and legal actions filed by affected individuals.

- **Reputation Damage:** The attack could tarnish Telstra's brand reputation and standing within the telecommunications industry, potentially affecting its long-term market position.
- **Regulatory Scrutiny:** Regulatory authorities may intensify their oversight, leading to increased compliance requirements and potential fines.
- **Operational Disruption:** The attack could disrupt Telstra's operations, including customer service, IT infrastructure, and customer support, causing further financial and reputational harm.

Threat Model #3

Stage 1: Unauthorised Access

The adversary employs various methods, such as social engineering, phishing attacks, or exploiting vulnerabilities in Telstra's systems, to gain unauthorised access to Telstra's internal network.

Stage 2: Reconnaissance and Lateral Movement

Once inside Telstra's network, the adversary conducts thorough reconnaissance to identify critical infrastructure and gain insights into Telstra's customer base.

The adversary starts moving laterally within the network, searching for vulnerable systems and escalating privileges.

Stage 3: Target Selection

The adversary identifies specific businesses and organisations that rely heavily on Telstra's network services.

Selection criteria may include business importance, size, industry, or perceived financial gain.

Stage 4: Covert Attack

The adversary launches covert attacks against the targeted businesses, exploiting their network connections through Telstra's infrastructure.

Attacks may include data exfiltration, ransomware, or unauthorised access to sensitive information.

Stage 5: Impact

As the attacks against Telstra's customers escalate, affected businesses experience disruptions to their operations, data breaches, financial losses, and reputational damage.

Telstra's reputation is severely tarnished as news of the breach and its impact on its customers becomes public knowledge.

Potential Consequences:

- **Financial Loss:** Telstra faces financial losses due to potential lawsuits, compensation claims from affected customers, and the cost of incident response and recovery.
- **Reputational Damage:** Telstra's reputation is significantly damaged, leading to customer attrition, decreased trust, and a hit to its market value.
- **Legal and Regulatory Consequences:** Telstra may face regulatory fines and legal actions for failing to protect customer data and network infrastructure.
- **Disruption for Telstra's Customers:** Businesses and organisations relying on Telstra's services experience operational disruptions, data breaches, and potential legal liability.

Sonic Healthcare

Identifying key assets:

- Data and Patient Records: Sonic Healthcare securely manages patient data and records, ensuring compliance with healthcare privacy regulations. This asset is essential for maintaining patient confidentiality and providing accurate healthcare services.
- Patient Billing and Financial Data
- Information Systems: Sonic Healthcare employs advanced information systems and health informatics platforms to manage patient data, laboratory operations, and reporting efficiently. These systems enhance workflow and data management.
- Intellectual Property and Lab Facilities

Methods of attack:

Ransomware

Ransomware attacks in the healthcare industry, exploiting vulnerabilities in the sector's digital infrastructure, have become a pressing concern. Cybercriminals consistently target healthcare organisations, encrypting critical patient data and demanding ransom payments for its release. These attacks not only jeopardise sensitive medical records but also disrupt essential healthcare services, potentially compromising patient safety. The following attack scenario showcases the intricate techniques deployed by cybercriminals to orchestrate ransomware attacks on healthcare organisations.

Threat Model #4

Stage 1: Initial Reconnaissance

The FIN11 group, armed with extensive knowledge of Sonic Healthcare's operations, begins by conducting thorough reconnaissance. They identify potential entry points, vulnerabilities, and key personnel within the organisation.

Stage 2: Phishing Campaign

The adversaries launch a sophisticated and targeted phishing campaign aimed at Sonic Healthcare's employees. Leveraging social engineering tactics and convincing lures (i.e. password expiry, company updates/announcements), they trick unsuspecting staff into opening malicious email attachments or clicking on infected links.

Stage 3: Infiltration and Initial Compromise

As Sonic Healthcare employees inadvertently engage with the malicious content, the ransomware is deployed. The Clop ransomware infiltrates Sonic Healthcare's network and starts to encrypt critical data, rendering it inaccessible.

Stage 4: "Double Extortion" Tactics

The attack's success lies in Clop's "double extortion" strategy. Not only does the ransomware encrypt data, but it also exfiltrates sensitive information, including patient records, confidential medical data, and financial records. The attackers then issue a ransom demand, threatening to release this sensitive data on the dark web if the demanded cryptocurrency ransom is not paid promptly.

Stage 5: Ransom Demand

Sonic Healthcare's operations are severely disrupted, and the group behind the attack demands a substantial ransom in cryptocurrency in exchange for the decryption keys. The demand comes with a tight deadline, putting immense pressure on the organisation to decide whether to pay the ransom or attempt data recovery through other means.

Potential Consequences:

Data Breach: Patient records and sensitive medical data are exposed, leading to potential privacy breaches and legal consequences.

Operational Disruption: Sonic Healthcare's ability to provide essential healthcare services is severely hampered, affecting patient care.

Financial Loss: Beyond the ransom payment, the incident results in extensive financial losses, including the costs of recovery and potential legal settlements.

Reputation Damage: The incident damages Sonic Healthcare's reputation, eroding patient trust and impacting its standing in the healthcare sector.

Commonwealth Bank of Australia

Identifying Key Assets

CommBank also has a diverse range of assets due to its large customer base; some of its critical assets and areas of focus include:

- **Customer Data:** Personally identifiable information, account and card information, asset information, and banking credentials.

- Digital Banking Platforms: Online and mobile banking services are essential assets, allowing customers to perform various banking activities, including payments, transfers, and account management.
- Data Assets: data and analytics to gain insights into customer behaviour, market trends, and risk management.
- Branches and Offices: Provide accessibility for customers and physical presence.
- Physical Assets: This includes ATMs and data centres, supporting customer transactions and data management.
- Payment Processing Systems: These are critical for processing customer and client transactions.

Methods of Attack:

Similar to the healthcare industry, ransomware attacks are also a persistent cyber threat to financial institutions as the rate of ransomware attacks in financial services continues to rise. The below scenario showcases how affiliates of ALPHV ransomware may launch an attack on the Commonwealth Bank of Australia.

Threat Model #5

Stage 1: Initial Reconnaissance and Entry

Threat actors affiliated with the ALPHV ransomware initiate their attack by conducting comprehensive reconnaissance on a targeted CBA's network. They identify potential vulnerabilities within the financial systems, employee endpoints, and critical infrastructure.

Through sophisticated social engineering tactics, the attackers distribute tailored phishing emails to employees. A finance executive falls victim to the phishing attack, unknowingly triggering the download of the ALPHV dropper onto CBA's network.

Stage 2: Malicious Payload Delivery and Network Propagation

The ALPHV dropper establishes a connection with the attackers' command and control server, providing them with a secure entry point into the CBA's network.

Exploiting vulnerabilities in financial software and utilising stolen or brute-forced credentials, the attackers move laterally across the network. They gain access to servers storing sensitive financial data.

Stage 3: ALPHV Ransomware Deployment.

With widespread access achieved, the threat actors deploy the ALPHV ransomware across critical servers, swiftly encrypting financial files and rendering them inaccessible.

Employees across the financial institution receive a ransom note on their screens, instructing them on how to contact the attackers for payment details. The note warns of the potential release of stolen financial data if the ransom is not paid within a specified timeframe.

Stage 4: Extortion and Data Exfiltration

In addition to encryption, the attackers implement the double extortion tactic. They upload a portion of stolen financial data to a dedicated leak site on the dark web, demonstrating their capability to expose sensitive information.

The threat actors threaten to release additional financial records publicly and initiate Distributed Denial of Service (DDoS) attacks on the financial institution's online services if the ransom demands are not met.

Stage 5: Response and Mitigation

CBA's cybersecurity and incident response teams promptly detect the ransomware attack. They isolate affected systems, disconnect them from the network, and initiate the restoration process from secure backups.

In adherence to regulatory guidelines and ethical considerations, the financial institution decides not to pay the ransom. Instead, they focus on rebuilding affected systems, strengthening cybersecurity measures, and improving employee awareness training to prevent future attacks.

Potential Consequences:

Data Breach: ALPHV ransomware may result in a data breach, exposing sensitive customer information, including financial records and transaction histories. This could lead to severe privacy breaches, regulatory scrutiny, and potential penalties for Commonwealth Bank.

Operational Disruption: The ransomware attack disrupts Commonwealth Bank's day-to-day operations, impacting financial services for both individual and corporate customers. Operational disruptions could lead to financial losses, increased customer dissatisfaction, and a loss of trust.

Financial Impact: The incident incurs substantial financial losses for Commonwealth Bank. These losses include the costs associated with restoring systems, conducting forensic investigations, implementing enhanced security measures, and potential legal settlements with affected parties.

Reputation Damage: The ransomware attack tarnishes Commonwealth Bank's reputation, depleting customer trust and damaging its standing within the financial sector. The public disclosure of the incident and potential data exposure can lead to a loss of confidence from customers, shareholders, and partners.

AGL Energy

AGL's assets include a wide range of infrastructure and resources related to energy generation, distribution, and retail.

Identifying key assets:

- Power generation assets
 - Power plants
 - Electricity and gas generation facilities
 - Power station equipment and machinery
 - Industrial Control Systems – play a vital role in the operation and management of energy generation and distribution infrastructure. These systems help control, monitor, and automate various processes in the energy sector.
- Transmission and distribution infrastructure
- Personal Identifiable Information
- Financial, Billing and Account Information Of clients and customers
- Government Contracts and Agreements
- Renewable Energy Assets
- Infrastructure and Real Estate

Methods of Attack:

Advanced persistent threat Campaign -

Nation-states, driven by geopolitical interests, strategic influence, and economic advantages, may target critical infrastructure within the energy sector to compromise national security, disrupt operations, and

gain a significant advantage in potential conflicts. This scenario delves into the potential cyber attack orchestrated by the nation-state-sponsored threat group Volt Typhoon on AGL.

Threat Model #6:

Stage 1: Initial Reconnaissance and Entry

Volt Typhoon, a state-sponsored Chinese threat group, initiates a targeted APT campaign against the critical infrastructure company AGL. The group leverages social engineering tactics, including spear phishing via email attachments, to deliver malicious payloads to employees.

Exploiting known vulnerabilities in Cisco routers, the attackers gain initial access through a compromised router.

Stage 2: Malicious Payload Delivery and Network Propagation

Once inside the network, Volt Typhoon employs command and scripting interpreters for execution. They use these interpreters to run malicious commands on compromised routers and move laterally within the network.

The threat actors escalate privileges using stolen credentials and compromised access tokens. This enables them to gain higher-level access across critical infrastructure systems.

Stage 3: APT Campaign Execution for DDoS

Volt Typhoon deploys a web shell on the compromised Cisco routers. This web shell, coded in Rust (as per the Volt Typhoon source), serves as a control mechanism and allows the threat actors to issue commands remotely.

The APT group leverages the compromised routers in a botnet for a Distributed Denial of Service (DDoS) attack, using application layer protocols for command and control. This massive DDoS attack disrupts normal operations within the energy distribution company.

Stage 4: Discovery and Response

Unfortunately, AGL's cybersecurity team detected the APT campaign after an extended period, during which the Volt Typhoon remained undetected. The attackers strategically delayed their DDoS attack, making detection more challenging. Despite this, the cybersecurity team initiates an immediate response upon detection. They work to swiftly contain the ongoing attack, isolate compromised systems, and start the process of eradicating the threat and enhancing security measures so this does not occur again.

Potential Consequences:

- **Massive DDoS Attack:** Overwhelms the energy company's network, causing operational paralysis.
- **Operational Disruption:** Prolonged service unavailability and critical infrastructure disruption.
- **Financial Losses:** Incurs costs for restoring operations, investigating the attack, and implementing cybersecurity measures.
- **Data Compromise:** Sensitive data within the energy company, including customer information and operational data, is exposed, leading to potential privacy breaches and regulatory penalties.
- **Reputation Damage:** Public disclosure of a cyber attack damages the company's reputation.

- Increased Cybersecurity Costs: Invests heavily in enhancing overall cybersecurity posture.

Mitigations

Implementing effective cybersecurity measures is crucial to safeguard against potential threats outlined in the report. The list of detailed mitigations below is based on MITRE ATT&CK techniques and threat models identified in the provided scenarios. These mitigations aim to enhance the overall resilience of the infrastructure by addressing specific vulnerabilities and potential attack vectors.

1. Implement multi-factor authentication to prevent actors from accessing valid accounts with stolen credentials:

Require multi-factor authentication for all user accounts, particularly privileged accounts. This prevents actors from accessing valid accounts with stolen credentials.

2. Implement network segmentation and network traffic filtering to prevent actors from directly connecting to remote access services they have established for persistence:

Prevents network traffic from unknown or untrusted origins from accessing remote services on internal systems. This prevents actors from directly connecting to remote access services they have established for persistence.

3. Configure the Windows Registry to require User Account (UAC) approval for any PsExec operations requiring administrator privileges to reduce the risk of lateral movement by PsExec:

Configuring the Windows Registry to mandate User Account Control (UAC) approval for PsExec operations adds an extra layer of authorisation. This hinders malicious actors from laterally moving within the network using PsExec, a legitimate administrative tool. This ensures that any attempt to execute privileged operations triggers UAC approval, providing an opportunity to authorise the action.

4. Implement application whitelisting to capture unusual activity:

Application whitelisting is an effective strategy to prevent the execution of unauthorised or malicious programs. By allowing only approved applications to run, this mitigation helps capture unusual activity and detect tools like Cobalt Strike. Operating in monitor mode, it provides a proactive approach to identifying potential security threats.

5. Perform daily backups and keep them offline and encrypted:

Performing daily backups and keeping them offline and encrypted is a crucial defence against data encryption attacks, such as ransomware. This practice ensures that in the event of a security incident, organisations can quickly recover and restore their operations without succumbing to extortion.

6. Use Strong Authentication to Mitigate SIM Swapping:

Implement two-factor authentication (2FA) or multi-factor authentication (MFA) on mobile accounts. This adds an additional layer of security beyond just the SIM card. It is vital to avoid SMS-based 2FA. Instead, organisations should opt for app-based authenticators or hardware tokens. Additionally, it is essential to set up a solid and unique personal identification number (PIN) or passcode for every mobile carrier account.

7. Facilitate phishing scam awareness in users and employ phishing preventative measures:

Conduct regular phishing awareness training for employees to recognise and report phishing attempts. Use email filtering solutions to identify and block phishing emails. Implement DMARC (Domain-based Message Authentication, Reporting, and Conformance) to prevent email spoofing and Phishing. Encourage users to verify unexpected emails or links directly with the sender before clicking. Regularly update and patch email systems to protect against known vulnerabilities.

8. Facilitate Help Desk Professional Training and employ User Verification processes:

Provide specialised training to help desk professionals recognise social engineering tactics and third-party attempts to extract sensitive information.

Establish a robust user verification process before help desk professionals release sensitive information, such as passwords or account details.

Regularly update and reinforce training programs to stay current with evolving social engineering techniques.

9. Regularly Patching Software:

Regularly patch applications and operating systems to address known vulnerabilities. This involves promptly applying security patches released by software vendors to eliminate known vulnerabilities.

Automated patch management tools can streamline the process, ensuring that all systems are up to date. Patching helps prevent exploitation by cyber threats, reduces the risk of unauthorised access, and enhances overall system resilience. Regular reviews of patch status and adherence to a well-defined patching policy contribute to a proactive cybersecurity posture.

10. Wireless Access Point Security:

Wireless access point security involves deploying robust encryption protocols like WPA3, implementing strong authentication measures such as multi-factor authentication, and regularly updating firmware to patch vulnerabilities. Furthermore, employing intrusion detection systems and monitoring for anomalies contribute to detecting and mitigating potential threats. Guest network isolation and physical security measures further enhance protection against unauthorised access and potential physical attacks.

11. Securing Remote Access:

Implement secure protocols for remote access, such as VPNs with robust encryption, to protect data during transmission. Regularly update and patch remote access solutions to address any vulnerabilities and ensure they align with current security standards.

12. Consistently Logging and Monitoring:

Implementing robust logging and monitoring practices across the IT infrastructure is essential for early threat detection and response. By capturing and analysing logs from various systems and network activities, security teams can identify anomalous behaviour, track potential indicators of compromise, and respond promptly to security incidents. Logging is particularly crucial for detecting and investigating unauthorised access, lateral movement, and other malicious activities.

In summary, to enhance cybersecurity defences, organisations should adopt proactive measures based on the provided mitigations. Implementing strategies like multi-factor authentication, network segmentation, application whitelisting, regular patching, and secure remote access can effectively reduce the risk of cyber threats. Coupled with user training, robust logging practices, and a well-defined incident response plan, these measures create a strong defence against unauthorised access and data breaches. Ongoing vigilance and adaptability to emerging threats are crucial to maintaining a secure cybersecurity posture. These recommendations aim to establish a resilient environment, safeguarding organisations against evolving cyber risks.

Conclusion

In conclusion, this report highlights the growing cybersecurity threats faced by critical infrastructure companies in Australia due to the increased targeting of these entities by global cyber threat actors. Through an in-depth analysis of specific trends within the threat landscape, rising threat actors, and their utilisation of MITRE ATT&CK techniques, we've identified critical vulnerabilities and potential consequences.

The evolving landscape of cyber threats necessitates a comprehensive and adaptive cybersecurity strategy. Mitigations presented in the report, such as application-based multi-factor authentication, secure remote access, in-depth user training, and robust OSINT monitoring, offer actionable steps to enhance organisations' security posture.

Organisations are urged to remain vigilant, employ threat intelligence, and foster a proactive cybersecurity culture. By implementing these measures, critical infrastructure companies can better defend against cyber threats and contribute to the resilience of the national infrastructure. This report serves as a call to action for organisations to prioritise and invest in cybersecurity to safeguard their operations and national interests.

Glossary

Access Token Manipulation: A tactic involving the manipulation of access tokens to gain unauthorised access.

AnyDesk: Remote desktop software for accessing computers remotely.

AWS: Amazon Web Services is a comprehensive cloud computing platform.

Azure Active Directory: Microsoft's cloud-based identity and access management service.

Backdoor Malware: Malicious software that provides unauthorised access to a system.

Batch Scripts: Scripts that automate a series of commands in a batch file.

Brute Force Attack: A method of gaining unauthorised access by trying various password combinations.

Clop Ransomware Variant: A specific variant of ransomware known as "Clop."

Command and Scripting Interpreter: Tools or languages used for interpreting and executing commands or scripts.

Credential Dumping: The extraction of stored credentials from a system.

Darknet Platform Ramp: Infiltrating or using darknet platforms for malicious purposes.

DDoS Attack: Distributed Denial of Service is a cyberattack aiming to disrupt services.

Default Logging Configurations: The preconfigured settings for recording and storing logs on a system.

DMARC (Domain-based Message Authentication, Reporting, and Conformance):

An email authentication and reporting protocol that helps protect organisations from email spoofing and Phishing.

Double Extortion Tactic: A ransomware tactic involving both encrypting files and threatening data exposure.

Endpoint Detection and Response (EDR) Products: Security solutions that monitor and respond to suspicious activities on endpoints.

Espionage: Covert activities to gather intelligence, often in a cyber context.

Extract Credentials: The unauthorised retrieval of login information or access credentials.

File Deletion: The removal of files from a system, often maliciously.

File Exfiltration: Unauthorised copying, transfer, or retrieval of files from a system.

File Transfer Service: Services facilitating the transfer of large files between systems, usually over an internet connection.

Financial Extraction: Illicit activities aimed at extracting financial assets.

Fortinet FortiGuard Devices: Security appliances and services provided by Fortinet for threat detection and prevention.

Freeware: Software that is free to use, often with limited features compared to paid versions.

Google Workspace: A suite of cloud computing and collaboration tools offered by Google.

Lateral Movement: The technique used by attackers to move horizontally across a network, gaining access to different systems.

Living off the Land Technique: A cyberattack method where attackers use legitimate system tools and resources present in the target environment aiming to stay undetected.

LockBit Ransomware: A type of ransomware that encrypts files and demands a ransom for their release.

LogMeIn: Remote desktop software for accessing computers remotely.

Malware: Malicious software designed to harm or exploit systems.

MFA Exploitation: Exploiting vulnerabilities in Multi-Factor Authentication processes.

MFA Fatigue: The frustration or weariness experienced by users due to repeated Multi-Factor Authentication.

Microsoft PowerShell: A task automation framework and scripting language, compelling on Windows systems.

Netsh: Network Shell command-line utility for network configuration on Windows.

Network Administration Tools: Software tools used for managing and monitoring computer networks.

NTDSUtil: A command-line tool for managing Active Directory databases on Windows servers.

Open-Source Tools: Software whose source code is publicly available for modification and distribution.

Phishing: Deceptive attempts to obtain sensitive information by posing as a trustworthy entity.

PowerShell: Microsoft's task automation framework and scripting language developed to help IT professionals configure systems and automate administrative tasks.

Psexec for Lateral Movement: A command-line tool used for executing processes on remote systems.

Ransomware: Malicious software that encrypts files, demanding a ransom for their release.

Ransomware-as-a-Service: A model where cybercriminals can rent or purchase ransomware to conduct attacks.

Remote Access Services/VMware: Services allowing remote access to computer systems.

Remote Desktop Services/VMware: Services allowing remote access to computer systems.

Remote Access: The ability of users to access a device or a network from any location. With that access, users can manage files and data that are stored on a remote device, allowing for continued collaboration and productivity from anywhere.

Tunnelling: A communication protocol that allows for the movement of data from one network to another.

Reverse SSH Tunnels: Creating secure communication channels for command-and-control purposes.

SIM Swapping: Fraudulent activity involving the unauthorised transfer of a user's mobile phone number to a new SIM card.

SMS Phishing: Phishing attacks are conducted through text messages.

Social Engineering Tactics: Manipulative techniques used to deceive individuals, including Phishing.

Soho Networks: Small Office/Home Office networks typically used by small businesses or remote workers.

SQL Injection Bug: Exploiting vulnerabilities in SQL databases to gain unauthorised access.

Stolen Credentials: Login information or access credentials obtained without authorisation.

System Discovery: Identifying and cataloguing devices and services within a network.

System Information Discovery: Gaining information about a system, its configuration, and installed software.

Telegram: A messaging app often used for communication, including by threat actors.

TOR Network: The Onion Router is a network enabling anonymous communication.

VPN: Virtual Private Network, providing secure network connections over the internet.

Voice Phishing: Deceptive attempts to obtain sensitive information using voice communication.

Wmic: Windows Management Instrumentation Command-line. A command-line tool used for system tasks on Windows computers.

References

AGL Energy Limited. (n.d.). "About Sonic Healthcare." Available: <https://www.agl.com.au/about-agl/who-we-are/our-company#:~:text=AGL%20operates%20Australia's%20largest%20private,gas%20production%20and%20storage%20assets>. [Accessed: October 5th, 2023].

Australian Cyber Security Centre. (2022, January). "Advisory 2022-004: ASD/ACSC Ransomware Profile: AlphV (aka BlackCat)." ACSC. Available: <https://www.cyber.gov.au/about-us/advisories/2022-004-asdacsc-ransomware-profile-alphv-aka-blackcat> [Accessed: September 27th, 2023].

Australian Cyber Security Centre. (2023, March). "Advisory 2023-03: ASD/ACSC Ransomware Profile: LockBit 3.0." ACSC. Available: <https://www.cyber.gov.au/about-us/advisories/2023-03-asdacsc-ransomware-profile-lockbit-3.0> [Accessed: October 10th, 2023].

Australian Cyber Security Centre. (2023, July). "ASD Cyber Threat Report: July 2022 - June 2023." ACSC. Available: <https://www.cyber.gov.au/about-us/reports-and-statistics/asd-cyber-threat-report-july-2022-june-2023> [Accessed: September 20th, 2023].

Australian Cyber Security Centre. (n.d.). "Ransomware." ACSC. Available: <https://www.cyber.gov.au/threats/types-threats/ransomware> [Accessed: October 3rd, 2023].

Check Point. (n.d.). "Nation-State Level Cyberattacks." Available: <https://www.checkpoint.com/cyber-hub/cyber-security/what-is-cyber-attack/nation-state-level->

[cyberattacks/#:~:text=Nation%2Dstate%20actors%20might%20look,and%20other%20persons%20of%20interest/](#) [Accessed October 1st,2023].

CrowdStrike. (n.d.). "Scattered Spider Attempts to Avoid Detection with Bring Your Own Vulnerable Driver Tactic." Available: <https://www.crowdstrike.com/blog/scattered-spider-attempts-to-avoid-detection-with-bring-your-own-vulnerable-driver-tactic/> [Accessed: October 15th, 2023].

CyberCX. (n.d.). "Threat Advisory Update: Russia-Ukraine Conflict Impacts for Australian and New Zealand Organisations." CyberCX Blog. Available: <https://cybercx.com.au/blog/threat-advisory-update-russia-ukraine-conflict-impacts-for-australian-and-new-zealand-organisations/> [Accessed: September 25th, 2023].

European Union Agency for Cybersecurity (ENISA). (n.d.). "Checking Up on Health: Ransomware Accounts for 54% of Cybersecurity Threats." Available: <https://www.enisa.europa.eu/news/checking-up-on-health-ransomware-accounts-for-54-of-cybersecurity-threats> [Accessed: October 8th, 2023].

Forbes. (n.d.). "Telstra." Available: <https://www.forbes.com/companies/telstra/?sh=512551fd1c8b> [Accessed: September 30th, 2023].

Malwarebytes. (2023, November). "Scattered Spider Ransomware Gang Falls Under Government Agency Scrutiny." Available: <https://www.malwarebytes.com/blog/news/2023/11/scattered-spider-ransomware-gang-falls-under-government-agency-scrutiny> [Accessed: October 2nd, 2023].

Mandiant. (n.d.). "M-Trends 2023." Available: [<https://www.mandiant.com/m-trends>] [Accessed: August 10th, 2023].

Minister for Defence. (2023, November 15th). "Release of Annual Cyber Threat Report 2022-23." Available: <https://www.minister.defence.gov.au/media-releases/2023-11-15/release-annual-cyber-threat-report-2022-23> [Accessed: September 22nd, 2023].

PwC Australia. (n.d.). "Cyber Security in the Healthcare Sector." Health Matters. Available: <https://www.pwc.com.au/health/health-matters/cyber-security-the-healthcare-sector.html> [Accessed: October 12th, 2023].

Security Info Watch. (n.d.). "Why Critical Infrastructure Is the New Target." Available: <https://www.securityinfowatch.com/security-executives/article/53069429/why-critical-infrastructure-is-the-new-target> [Accessed: September 28th, 2023].

Sonic Healthcare. (n.d.). "About Sonic Healthcare." Available: <https://www.sonichealthcare.com/about-sonic/> [Accessed: October 7th, 2023].

Telstra. (n.d.). "Telstra." Available: <https://www.forbes.com/companies/telstra/?sh=512551fd1c8b> [Accessed: October 1st, 2023].

Trend Micro. (n.d.). "Cybercriminals." Available: <https://www.trendmicro.com/vinfo/us/security/definition/cybercriminals> [Accessed: October 6th, 2023].